

ARQUIVO ANEXO 1 — Frameworks Oficiais do Guardiã Digital TcheloEduca

Use este arquivo como referência técnica obrigatória nas análises preventivas de sites.

1. LGPD — Lei Geral de Proteção de Dados

Avalie o site conforme a Lei nº 13.709/2018.

Verifique:

- se há coleta, uso, armazenamento, publicação, compartilhamento ou eliminação de dados pessoais;
- se há dados de crianças ou adolescentes;
- se há dados sensíveis;
- se há política de privacidade;
- se há identificação do controlador;
- se há canal do encarregado/DPO;
- se há base legal informada;
- se há transparência sobre finalidades;
- se há retenção definida;
- se há canal para exercício de direitos;
- se há medidas de segurança;
- se há cookies, pixels, analytics ou publicidade comportamental.

Princípios LGPD a avaliar:

- finalidade;
- adequação;
- necessidade;
- livre acesso;
- qualidade dos dados;
- transparência;
- segurança;
- prevenção;
- não discriminação;
- responsabilização e prestação de contas.

Para crianças e adolescentes, aplique sempre o critério do melhor interesse.

2. ECA Digital

Avalie se o site ou ambiente digital é acessível, direcionado ou atrativo para crianças e adolescentes.

Verifique:

- coleta de dados de menores;
- publicação de nomes, fotos, vídeos, voz, escola, turma, série ou rotina;

- conteúdo impróprio;
- contato entre usuários;
- risco de contato inadequado entre adultos e menores;
- publicidade direcionada;
- perfilamento comportamental;
- rastreamento para anúncios;
- cookies não necessários;
- geolocalização;
- mecanismos de recompensa, ranking ou uso compulsivo;
- ausência de privacidade por padrão;
- ausência de canal de denúncia;
- ausência de supervisão parental.

Quando o site for escolar, educacional, infantil, juvenil ou familiar, use régua mais protetiva.

3. Guias da ANPD

Use os guias e orientações da ANPD como referência técnica.

Cookies

Verifique:

- se há banner de cookies;
- se há política de cookies;
- se cookies não necessários são bloqueados antes do consentimento;
- se há opção clara de recusar;
- se aceitar é tão fácil quanto recusar;
- se há granularidade por categoria;
- se há cookies de analytics, publicidade, remarketing ou redes sociais;
- se a política informa nome do cookie, fornecedor, finalidade e duração.

Agentes de tratamento e encarregado

Verifique:

- quem é o controlador;
- quem são os operadores;
- se há terceiros ou fornecedores;
- se há encarregado/DPO;
- se há canal de contato de privacidade;
- se o canal é claro, acessível e específico.

Legítimo interesse

Quando o site parecer usar legítimo interesse, marketing institucional, analytics, publicação de aprovados, fotos, depoimentos ou divulgação de alunos, avalie:

- finalidade legítima;
- necessidade;
- expectativa razoável do titular;

- impacto sobre o titular;
- salvaguardas;
- possibilidade de oposição;
- proteção reforçada para crianças e adolescentes.

Segurança da informação

Verifique:

- HTTPS;
- áreas de login;
- portais restritos;
- controle de acesso;
- autenticação;
- gestão de senhas;
- logs;
- fornecedores;
- backup;
- resposta a incidentes;
- prevenção de exposição indevida.

Incidentes e dosimetria

Avalie se há risco de:

- exposição indevida;
- publicação excessiva;
- vazamento;
- acesso não autorizado;
- dano relevante ao titular;
- necessidade de bloqueio, remoção, correção ou comunicação.

4. PPSI — Programa de Privacidade e Segurança da Informação

Use como referência de maturidade, mesmo quando o site analisado for privado.

Avalie:

- governança de privacidade;
- governança de segurança;
- inventário de dados;
- gestão de riscos;
- políticas e procedimentos;
- conscientização de pessoas;
- gestão de terceiros;
- plano de melhoria;
- resposta a incidentes;
- maturidade de controles.

Perguntas práticas:

- o site demonstra governança?
- há política clara?
- há canal de privacidade?
- há processo de direitos do titular?
- há controle de terceiros?
- há plano para reduzir riscos?
- há tratamento especial para crianças e adolescentes?

5. ISO/IEC 27001

Use como referência de Sistema de Gestão de Segurança da Informação.

Avalie:

- confidencialidade;
- integridade;
- disponibilidade;
- controle de acesso;
- autenticação;
- gestão de riscos;
- segurança em fornecedores;
- registros e logs;
- resposta a incidentes;
- continuidade;
- proteção contra acesso indevido;
- segurança em formulários e portais.

Em sites escolares, observe especialmente:

- portal do aluno;
- portal dos responsáveis;
- login de professores;
- sistemas de matrícula;
- dados acadêmicos;
- dados financeiros;
- dados de saúde;
- documentos de menores.

6. ISO/IEC 27701

Use como referência de Sistema de Gestão de Privacidade da Informação.

Avalie:

- controlador;
- operador;
- inventário de dados pessoais;
- finalidades;
- bases legais;

- direitos do titular;
- retenção;
- descarte;
- compartilhamento;
- transferência internacional;
- privacidade por padrão;
- registro de operações;
- tratamento de dados de menores;
- comunicação com titulares.

Perguntas práticas:

- o site informa quais dados coleta?
- informa por que coleta?
- informa com quem compartilha?
- informa por quanto tempo mantém?
- informa como excluir ou corrigir?
- informa tratamento de crianças/adolescentes?

7. NIST Privacy Framework

Use as funções:

Identify-P

Identifique:

- dados pessoais tratados;
- titulares afetados;
- sistemas e terceiros;
- cookies e identificadores;
- riscos de privacidade.

Govern-P

Avalie:

- políticas;
- papéis e responsabilidades;
- governança;
- gestão de risco;
- prestação de contas.

Control-P

Avalie:

- minimização;
- consentimento;
- preferências de privacidade;
- retenção;

- exclusão;
- limitação de uso;
- controle pelo titular.

Communicate-P

Avalie:

- transparência;
- avisos de privacidade;
- linguagem clara;
- comunicação com titulares;
- canal para direitos.

Protect-P

Avalie:

- segurança;
- controle de acesso;
- criptografia;
- logs;
- proteção contra exposição;
- resposta a incidentes.

8. CIS Controls

Use como referência de controles técnicos básicos.

Avalie, quando possível pelo conteúdo público:

- inventário de ativos;
- inventário de softwares e plataformas;
- proteção de dados;
- configuração segura;
- gestão de contas;
- gestão de acessos;
- logs;
- proteção de navegador e e-mail;
- gestão de vulnerabilidades;
- fornecedores;
- resposta a incidentes;
- treinamento de usuários;
- segurança de aplicações.

Em análise pública, não execute testes invasivos. Apenas registre indícios, ausência de informação ou necessidade de auditoria técnica.

9. Privacy by Design

Use como abordagem transversal.

Avalie:

- privacidade desde a concepção;
- privacidade como padrão;
- minimização de dados;
- transparência;
- segurança ponta a ponta;
- controle pelo titular;
- prevenção de danos;
- proteção reforçada para menores;
- facilidade de remoção;
- linguagem clara.

Perguntas práticas:

- o site coleta só o necessário?
- a configuração padrão protege o usuário?
- há opção de recusar cookies?
- há canal para remover dados?
- há aviso no ponto de coleta?
- há proteção especial para crianças/adolescentes?
- há exposição pública desnecessária?

10. Aplicação integrada

Em cada achado, relacione pelo menos um framework.

Exemplo:

Achado: página pública lista alunos aprovados em universidades.

Análise integrada:

- LGPD: dado pessoal, finalidade, necessidade, transparência e melhor interesse.
- ECA Digital: exposição de adolescente ou recém-egresso em ambiente digital.
- ANPD: avaliar base legal, legítimo interesse, direitos do titular e minimização.
- ISO 27701: inventário, base legal, retenção e canal de direitos.
- NIST: Identify-P, Communicate-P, Control-P e Protect-P.
- Privacy by Design: reduzir exposição e permitir remoção.
- CIS/ISO 27001: avaliar indexação, controle de acesso e proteção contra exposição indevida.

Classificação sugerida: risco alto, salvo se houver evidência pública clara de autorização, minimização, prazo de retenção e canal de remoção.